

Proyecto NIST - Respuesta a Incidente de Ransomware (TechCo) - Eduard Requena

Fecha: 2026-01-02 | Autor: Eduard Requena



1. Contexto (TechCo) y objetivo del proyecto

TechCo (empresa ficticia) da servicios en la nube y guarda datos sensibles de clientes. Ha sufrido un ataque de ransomware por un correo de phishing con un adjunto tipo 'factura'. El ransomware se propagó con rapidez porque no existía segmentación adecuada ni un sistema de monitorización y alertas eficaz.

Objetivo: desarrollar un plan de respuesta basado en NIST, para que TechCo pueda responder mejor, recuperar antes y reducir la probabilidad de recurrencia.

REFERENCIAS

[NIST Cybersecurity Framework \(CSF\) 2.0 - NIST CSWP 29 \(2024\).](#)

[NIST SP 800-61 Rev. 3 - Incident Response Recommendations and Considerations for Cyber Risk Management \(2025\).](#)

[NISTIR 8374 - Ransomware Risk Management: A Cybersecurity Framework Profile \(2022\).](#)

Fecha: 07/01/2026

2. Alcance, supuestos y criterios

Alcance: endpoints de usuarios, servidores de archivos, base de datos de clientes, infraestructura de backup, red interna y servicios cloud asociados.

2.1 Supuestos

Voy a asumir que TechCo tiene:

- o ActiveDirectory/IdentityProviders para identidades,
- o un firewall,
- o backups 'clásicos' (sin inmutabilidad).
- o También asumo que hay un equipo IT pequeño y que Seguridad no es un departamento enorme, más bien 2-3 personas.

2.2 Criterios de éxito

- o Detectar el incidente antes de que cifre todo (MTTD baja).
- o Contener en menos de 60 minutos desde detección (ideal).
- o Restaurar servicios críticos.
- o Saber qué comunicar, a quién y cuándo (sin improvisar mails).
- o Que los backups vuelvan a ser 'backups' de verdad: aislados, probados y con restore validado.

3. Marco NIST utilizado (resumen)

- o Contener rápido para frenar la propagación.
- o Recuperar lo crítico primero (identidad, BBDD y servicios esenciales) usando copias verificadas.
- o Además, existe un perfil NIST específico para ransomware (NISTIR 8374) que sirve como checklist de cosas que normalmente faltan.

REFERENCIAS

[NIST Cybersecurity Framework \(CSF\) 2.0 - NIST CSWP 29 \(2024\).](#)

[NIST SP 800-61 Rev. 3 - Incident Response Recommendations and Considerations for Cyber Risk Management \(2025\).](#)

[NISTIR 8374 - Ransomware Risk Management: A Cybersecurity Framework Profile \(2022\).](#)

4. Identificación (Identify) - activos críticos y puntos debiles.

4.1 Activos críticos

- o Servidor de archivos: documentos operativos, contratos, plantillas, etc.
- o Para ordenar este plan me apoyo en NIST CSF 2.0, que divide el trabajo en bloques: Gobierno, Identificación, Protección, Detección, Respuesta y Recuperación.
- o Servicios de identidad (AD/IdP), DNS, certificados: si esto cae, es el efecto dominó.
- o Infraestructura de backup: repositorios, cuentas de servicio, storage.
- o Plataforma cloud de TechCo: paneles, APIs, credenciales.

4.2 Vulnerabilidades observadas Phishing + adjunto malicioso: falta de controles de correo y/o concienciación práctica.

- o Red plana (sin segmentación): movimiento lateral fácil.
- o Backups dentro de la misma red comprometida: también resultaron cifrados.
- o Sin monitorización en tiempo real: detección tardía por quejas de usuarios.
- o Privilegios excesivos o credenciales reutilizadas (posible).

4.3 Impacto (y por qué es grave)

Impacto principal: indisponibilidad por cifrado. Impacto secundario: posible exfiltración (doble extorsión). En un negocio de datos esto es el combo perfecto para perder clientes.

Para los pasos prácticos de respuesta a incidentes me guío por NIST SP 800-61 Rev. 3 (qué hacer, en qué orden, y cómo coordinarlo).

5.1 Medidas rápidas de alto impacto

- o MFA obligatorio en correo, VPN, cloud y cuentas privilegiadas.

REFERENCIAS

[NIST Cybersecurity Framework \(CSF\) 2.0 - NIST CSWP 29 \(2024\).](#)

[NIST SP 800-61 Rev. 3 - Incident Response Recommendations and Considerations for Cyber Risk Management \(2025\).](#)

[NISTIR 8374 - Ransomware Risk Management: A Cybersecurity Framework Profile \(2022\).](#)

- o Como apoyo, reviso el perfil NISTIR 8374 (ransomware) a modo de checklist para no dejarme lo básico.
- o Segmentación: usuarios / servidores / admin / backups (y reglas mínimas entre zonas).
- o EDR en endpoints y servidores con aislamiento remoto (para cortar rápido).
- o PAM o al menos cuentas admin separadas + rotación de credenciales/secretos.
- o Backups 3-2-1 con copia offline o inmutable y pruebas periódicas de restauración.

5.2 Políticas y procedimientos de apoyo

- o Política de Respuesta a Incidentes (IR Policy).
- o Procedimiento de gestión de ransomware (playbook).
- o Política de backups: retención, inmutabilidad/aislamiento, y pruebas de restauración.
- o Política de correo y uso de adjuntos/links (y sanciones, sí).
- o Gestión de vulnerabilidades y parches (ventanas, prioridad, excepciones).

6. Detección (Detect) - detección temprana

6.1 Telemetría mínima

- o Logs centralizados: AD/IdP, EDR, servidores, firewall, correo, backups.
- o Alertas por comportamiento: cifrado masivo, renombrados, shadow copies borradas, uso raro de herramientas admin.
- o Monitorización de autenticaciones: login anómalo, uso de cuentas admin fuera de horario, múltiples fallos, etc.

6.2 Protocolo de alerta temprana (desencadenadores y escalado)

Ejemplos de desencadenadores:

- o Más de X ficheros modificados por minuto en un share crítico.

REFERENCIAS

[NIST Cybersecurity Framework \(CSF\) 2.0 - NIST CSWP 29 \(2024\).](#)

[NIST SP 800-61 Rev. 3 - Incident Response Recommendations and Considerations for Cyber Risk Management \(2025\).](#)

[NISTIR 8374 - Ransomware Risk Management: A Cybersecurity Framework Profile \(2022\).](#)

- o Proceso desconocido tocando extensiones tipo .docx/.xlsx en masa.
- o Creación de tareas programadas o servicios nuevos en varios hosts.
- o EDR/antivirus avanzado en endpoints y servidores, idealmente con opción de aislamiento remoto para cortar rápido.

Cuentas admin separadas (no usar la cuenta admin para correo/navegar) + cambio/rotación de credenciales tras el incidente.

7. Respuesta (Respond) - plan detallado (paso a paso)

7.1 Equipo y roles (roles y responsabilidades)

Rol	Responsable	Qué hace (resumen)
Incident Commander (IC)	Dirección/IT Manager	Coordina, decide prioridades y aprueba acciones críticas.
IR Lead (seguridad)	Seguridad	Análisis, revisión de alcance, contención técnica y coordinación de evidencias.
Infra / Operaciones	IT Ops	Aislamiento de red, reconstrucción (rebuild) y restauración (restore) de sistemas.
Legal/Compliance	Legal/DPO	Asesoría legal y notificaciones (si aplica), incluyendo reguladores.
Comunicaciones	PR/Comms	Mensajes internos/externos y coordinación del portavoz único.

7.2 línea de tiempo de operabilidad (primeras 24h)

0-2 horas: contención inicial

- o Aislar sistemas afectados (EDR isolate o VLAN cuarentena).
- o Política de correo y uso de adjuntos/enlaces (con reglas claras y medidas si hay incumplimientos).

REFERENCIAS

[NIST Cybersecurity Framework \(CSF\) 2.0 - NIST CSWP 29 \(2024\).](#)

[NIST SP 800-61 Rev. 3 - Incident Response Recommendations and Considerations for Cyber Risk Management \(2025\).](#)

[NISTIR 8374 - Ransomware Risk Management: A Cybersecurity Framework Profile \(2022\).](#)

- o Deshabilitar cuentas sospechosas, reset de admins y rotación de secretos.
- o Preservar evidencia: nota de rescate, hashes, logs, snapshots.
- o Canal de crisis único + bitácora (quién decide qué y cuándo).
- o Logs centralizados (lo mínimo): AD/IdP, endpoints/servidores, firewall, correo y backups (si se dispone, también EDR).

2-8 horas: contención y análisis

- o Identificar el origen del incidente (correo, endpoint, usuario).
- o Buscar IOCs en EDR/SIEM y extender contención.
- o Verificar si hubo exfiltración (proxy, firewall, cloud logs).
- o Decidir estrategia de reconstrucción (no restaurar sobre sistemas sucios).

8-24 horas: erradicación y empezar recuperación

Rehacer los endpoints y reconstrucción de servidores críticos.

Parches antes de volver a conectar.

Restauración priorizada (identidad, BBDD, servicios core, ficheros).

Comunicaciones a clientes según legal.

7.3 Comunicación (interna y externa)

Regla: portavoz único. Las comunicaciones externas se coordinan con Legal y Dirección.

- o Interna: instrucciones claras (no reiniciar equipos, no reconectar, reportar síntomas).
- o Externa: status page / comunicación a clientes con hechos verificados.
- o Agencias reguladoras: si hay datos personales afectados, preparar notificación formal.

7.4 Sobre pagar rescate (decisión desagradable)

No se paga por defecto. Pagar no garantiza descifrado ni evita filtración. Si se valora, decide Dirección con Legal y aseguradora. Revisar implicaciones con respecto a las sanciones, con aprobación de Dirección y Legal.

REFERENCIAS

[NIST Cybersecurity Framework \(CSF\) 2.0 - NIST CSWP 29 \(2024\).](#)

[NIST SP 800-61 Rev. 3 - Incident Response Recommendations and Considerations for Cyber Risk Management \(2025\).](#)

[NISTIR 8374 - Ransomware Risk Management: A Cybersecurity Framework Profile \(2022\).](#)

8. Recuperación (Recover) - restauración segura

8.1 Orden recomendado de recuperación

- o Identidades (AD/IdP) y accesos privilegiados.
- o Base de datos de clientes (validación de integridad).
- o Servicios core (APIs, paneles, autenticación).
- o Servidor de archivos por prioridades de negocio.
- o Backups: rediseño para que no vuelva a pasar lo mismo.

8.2 Backups resilientes (requisitos mínimos)

- o Copia offline o inmutable y separada de credenciales de dominio.
- o Cuenta de backup sin permisos de admin del dominio (si se puede).
- o Prueba de restore mensual y simulacro anual completo.
- o Inventario de qué se puede restaurar y cuánto tarda.

8.3 Continuidad de negocio (BCP) en modo 'degradado'

- o Procesos manuales temporales para soporte y facturación.
- o Entorno limpio temporal (cloud) para servicios mínimos.
- o Externa: página de estado y comunicación a clientes con hechos verificados (sin especular).

9. Mejora continua y Gobierno (Govern)

9.1 Lecciones aprendidas (post-incidente)

No se recomienda pagar por defecto, porque no garantiza recuperar todo ni evita filtración. Si se llega a valorar, lo decide Dirección con Legal y la aseguradora, revisando riesgos y alternativas de recuperación.

REFERENCIAS

[NIST Cybersecurity Framework \(CSF\) 2.0 - NIST CSWP 29 \(2024\).](#)

[NIST SP 800-61 Rev. 3 - Incident Response Recommendations and Considerations for Cyber Risk Management \(2025\).](#)

[NISTIR 8374 - Ransomware Risk Management: A Cybersecurity Framework Profile \(2022\).](#)

Revisar también implicaciones legales (incluidas posibles sanciones) con aprobación de Dirección y Legal.

10. Anexos

Anexo: Checklist 'primeras 2 horas'

- o Aislar host(s) y segmentos afectados.
- o Parar comparticiones (shares) críticas.
- o Reset de credenciales admin, rotación de secretos.
- o Preservar evidencia (nota rescate, logs, snapshots).
- o Abrir canal de crisis y bitácora.
- o Escalar a Legal + Dirección + aseguradora.

Después del incidente: reunión en 72h-2 semanas. Se revisa qué falló, qué funcionó y qué decisiones se tomaron tarde o no ayudaron (sin buscar un culpable).

REFERENCIAS

[NIST Cybersecurity Framework \(CSF\) 2.0 - NIST CSWP 29 \(2024\).](#)

[NIST SP 800-61 Rev. 3 - Incident Response Recommendations and Considerations for Cyber Risk Management \(2025\).](#)

[NISTIR 8374 - Ransomware Risk Management: A Cybersecurity Framework Profile \(2022\).](#)